IAM-LOCAL · ACSI

ARCHITECTURE · FONCTIONNEMENT · EXPLOITATION

Comprendre le projet IAM-Local

Le guide de référence pour comprendre comment les identités, les applications, les rôles et les connexions SSO s'articulent.

En une phrase
IAM-Local centralise les comptes et les décisions d'accès; chaque application cliente conserve son interface et applique les permissions reçues.

Guide technique et fonctionnel

Édition du 5 octobre 2026

01 · VUE D'ENSEMBLE

À quoi sert IAM-Local ?

IAM-Local est une plateforme d'Identity and Access Management (IAM) écrite principalement en PHP. Elle fournit un point central pour authentifier les personnes, publier les applications disponibles et définir les droits par application.

Ce que l'IAM centralise

- Comptes, profils, états et rattachements organisationnels.
- Connexion, politique de mot de passe, MFA et sessions.
- Catalogue d'applications, rôles, permissions et attributions.
- Journal d'audit et émission de jetons SSO/OIDC.

Ce que l'IAM ne remplace pas

- Le code métier, les écrans et les données de chaque application.
- La base de données métier de l'application cliente.
- Le contrôle de permission dans une application qui n'applique pas les droits reçus.

Architecture simplifiée

Utilisateur
Ouvre le portail ou une application.

→

IAM-Local
Authentifie, vérifie MFA et autorisations.

→

Application cliente
Établit sa session et contrôle les permissions.

> **Deux mécanismes d'intégration.** Le SSO natif émet un jeton court à usage unique échangé côté serveur. OAuth 2.0 / OIDC suit un protocole standard et convient aux clients Django, Flutter ou autres frameworks qui disposent d'un connecteur OIDC.

Environnement documenté : PHP 8.x, Apache/WAMP, MySQL et URL locale `http://localhost/IAM-Local`. Ce guide décrit le dépôt IAM-Local; les projets métier voisins restent des applications séparées.

02 · CARTE DU DÉPÔT

Où se trouve chaque fonction ?

Le code est organisé par responsabilité : pages d'administration, API JSON, services communs et points d'entrée protocolaires.

Dossier / fichier	Responsabilité	Exemples
`admin/`	Console graphique protégée par authentification et rôle administrateur.	Applications, utilisateurs, rôles, audit, sessions, OAuth/OIDC.
`api/`	API REST JSON consommée par les applications et outils.	Login, utilisateurs, permissions, sessions, SSO validate, OAuth token.
`includes/`	Logique partagée : base, sessions, règles, mail et OAuth.	`functions.php`, `oauth.php`, `mailer.php`.
`sso/` et `oauth.php`	Autorisation interactive et retour vers les clients.	Émission SSO; consentement Authorization Code.
`client/` et `admin/_sso_generator.php`	Bibliothèque PHP et génération du garde pour les applications compatibles.	Garde auto-prepend, client SSO, téléchargement.
`config/`	Configuration d'environnement générée à l'installation.	URL IAM, base MySQL, durées de session, MFA, secrets.
`sql/`	Schéma, jeux de données et scripts de migration.	`schema.sql`, seeds, migration des rôles par application.
`docs/`	Guides, cahier des charges et diagrammes.	Guide utilisateur, UML, ce guide complet.

Pages principales

Espace utilisateur
`login.php`, `portal.php`, `profile.php`, `mfa.php`, `logout.php`.

Installation et lancement
`install.php` initialise la base et la configuration; `index.php` oriente vers l'espace approprié.

> **Configuration sensible.** `config/config.php` contient les paramètres d'accès et secrets. Ne publiez pas ce fichier, les fichiers `.env` ni les sauvegardes de base.

03 · MODÈLE MÉTIER

Identités, applications et droits

Le contrôle d'accès suit le modèle RBAC : un utilisateur reçoit un ou plusieurs rôles pour une application; chaque rôle regroupe des permissions.

Utilisateur
Identité, état, MFA, organisation.

→

Attribution
`user_roles` lie utilisateur, rôle et application.

→

Rôle applicatif
`roles.application_id` définit son propriétaire.

→

Permissions
`role_permissions` relie le rôle aux droits.

Ensemble de tables	Contenu	Pourquoi c'est important
`users`, `organizations`, `groups`, `user_groups`	Identités et structure organisationnelle.	La connexion identifie l'utilisateur; le statut détermine s'il peut continuer.
`applications`	Code, nom, URL, état, configuration de pont SSO.	Le portail affiche les applications actives; l'autorisation vérifie la cible.
`roles`, `permissions`, `role_permissions`, `user_roles`	Rôles propres à une application et droits fins.	Les rôles d'une application ne doivent pas être copiés à une autre.
`sessions`, `sso_tokens`	Sessions IAM révocables et jetons SSO courts.	Un jeton SSO n'est valable qu'une fois et est consommé de façon transactionnelle.
`oauth_clients`, `oauth_codes`, `oauth_keys`, `refresh_tokens`	Clients OIDC, codes, clés RSA et rafraîchissements.	Sépare client confidentiel serveur et client public PKCE.
`otp_codes`, `mfa_devices`, `login_attempts`, `audit_logs`	MFA, anti-brute-force et traçabilité.	Supporte les contrôles et les investigations.

> **Conséquence pratique.** Si la liste de rôles est vide pour une nouvelle application, ce n'est pas nécessairement une panne : il faut créer un rôle propriétaire de cette application, lui attacher des permissions, puis attribuer ce rôle à l'utilisateur.

Le schéma de référence est `sql/schema.sql`; certains déploiements anciens sont adaptés par des migrations idempotentes au démarrage ou à la mise à niveau.

04 · PARCOURS D'AUTHENTIFICATION

Comment une connexion se déroule

Connexion au portail IAM

1. L'utilisateur saisit identifiant/e-mail/téléphone et mot de passe.
2. IAM contrôle le statut, le hash bcrypt, les tentatives et le verrouillage.
3. Selon la politique, IAM exige le MFA par code e-mail.
4. Un changement de mot de passe peut être imposé au premier accès ou après expiration.
5. IAM ouvre sa session puis affiche le portail et les applications autorisées.

SSO natif vers une application cliente

1 · Demande
Le garde intercepte l'accès et redirige vers IAM.

→

2 · Contrôles
IAM vérifie application active, session/MFA et rôle.

→

3 · Jeton
Jeton aléatoire, expiration courte (60 s par défaut), usage unique.

→

4 · Échange
L'application appelle `api/sso/validate.php` et ouvre sa session locale.

L'application reçoit profil, rôles et permissions filtrés pour son identifiant. Elle doit ensuite vérifier les permissions sur ses pages et actions; l'IAM ne peut pas deviner les opérations métier propres à l'application.

OIDC Authorization Code + PKCE

OIDC convient aux frameworks non-PHP qui ont un connecteur : redirection vers l'autorisation IAM, consentement, retour avec un code, échange contre des jetons, puis lecture du profil via UserInfo. Django utilise un client confidentiel côté serveur; Flutter utilise un client public sans secret avec PKCE S256.

Élément	Valeur / rôle
Issuer	`IAM_BASE_URL`
Découverte	`/.well-known/openid-configuration.php`
Autorisation	`/oauth.php`
Token / UserInfo / JWKS	`/api/oauth/token.php`, `/api/oauth/userinfo.php`, `/api/oauth/jwks.php`
Scopes	`openid`, `profile`, `email`

> **Limite à connaître.** UserInfo fournit l'identité et les claims de profil; les rôles et permissions applicatifs ne sont pas actuellement renvoyés comme claims OIDC.

05 · MODULES FONCTIONNELS

Ce que l’administration permet de gérer

Module	Fonctions principales	Notion associée
Tableau de bord	Indicateurs et accès rapides aux fonctions d’administration.	Vue de synthèse.
Utilisateurs	Créer, modifier, désactiver, réinitialiser, importer; attribuer rôles et organisations.	Cycle de vie des identités.
Groupes	Organiser des utilisateurs en ensembles réutilisables.	Organisation logique.
Rôles & permissions	Créer les droits, composer les rôles, associer permissions et applications.	RBAC.
Applications	Catalogue, état, SSO, permissions, accès utilisateurs, intégration et diagnostic local.	Clients métier.
Organisations	Hiérarchie et rattachement institutionnel.	Contexte du compte.
Sessions / audit	Consulter ou révoquer les sessions; filtrer l’historique d’événements.	Contrôle opérationnel.
OAuth / OIDC	Créer clients Django/serveur, Flutter public PKCE et services machine-à-machine; rotation JWKS.	Fédération protocolée.
E-mail & paramètres	Configurer SMTP/OAuth fournisseur, politique de mot de passe, CORS et sécurité API.	Configuration d’exploitation.

Parcours recommandé pour onboarder une application

1. Créer la fiche d’application et vérifier URL/hébergement.
2. Définir des permissions métier explicites.
3. Créer des rôles propres à l’application et leur attribuer les permissions nécessaires.
4. Attribuer un rôle à chaque utilisateur autorisé.
5. Configurer l’intégration SSO native PHP ou enregistrer un client OIDC.
6. Tester avec un compte à privilèges minimaux, puis vérifier l’audit.

06 · API ET INTÉGRATIONS

Interfaces utilisées par les clients

Famille	Endpoint	Usage
SSO	`/sso/authorize.php`	Contrôle l'application et l'accès; émet le jeton à usage unique.
SSO	`/api/sso/validate.php`	Échange POST du jeton et du code application contre identité, rôles et permissions.
Identité	`/api/login.php`, `/api/logout.php`, `/api/userinfo.php`	Connexion API, sortie, informations utilisateur.
Accès	`/api/roles.php`, `/api/permissions.php`	Lire rôles et droits autorisés.
MFA	`/api/mfa/send.php`, `/api/mfa/verify.php`	Émettre et vérifier un OTP.
OIDC	`/oauth.php`, `/api/oauth/token.php`, `/api/oauth/userinfo.php`	Autorisation, échange/rotation de jetons et profil.
OIDC	`/api/oauth/jwks.php`, `/.well-known/openid-configuration.php`	Clés publiques et découverte.
Administration	`/api/users.php`, `/api/roles.php`, `/api/sessions.php`, `/api/audit_logs.php`	API d'administration protégées par les contrôles IAM.

Intégration selon la technologie

PHP local

Garde généré, auto-prepend Apache si le module et les droits le permettent; sinon inclusion manuelle. Le garde appelle l'API de validation.

Django / serveur

Client OIDC confidentiel. Le secret reste côté serveur; callback HTTPS exact en production. Utiliser une bibliothèque OIDC maintenue.

Flutter / mobile

Client public sans secret. PKCE S256 obligatoire; URI de callback native déclarée à l'identique dans l'app et IAM.

SPA / autre framework

Doit disposer d'un connecteur OIDC. Les secrets ne vont jamais dans le navigateur. Une passerelle ou un adaptateur peut être nécessaire.

L'enregistrement graphique prépare les paramètres du client; il ne peut pas installer automatiquement une bibliothèque ou modifier un projet externe arbitraire.

07 · SÉCURITÉ

Les contrôles structurants

Risque	Contrôle implémenté	Point d'exploitation
Vol de mot de passe	Hash bcrypt, politique et historique des mots de passe.	Forcer le changement d'un mot de passe initial.
Force brute	Compteur d'échecs, verrouillage, limites par IP/compte.	Vérifier le journal lors d'un verrouillage.
Compte compromis	MFA OTP, expiration et révocation de sessions.	SMTP vide = mode démonstration local; configurer un vrai SMTP pour usage réel.
Rejeu SSO	Jeton aléatoire, courte durée, consommation atomique à usage unique.	Ne jamais réutiliser ou exposer un jeton dans une capture publique.
Redirection ouverte	Vérification de l'URL de retour et URI OIDC enregistrées.	Utiliser en production des URI HTTPS exactes.
Secret client exposé	Secret serveur affiché une seule fois; client Flutter sans secret.	Conserver les secrets confidentiels dans le serveur, hors dépôt Git.
Élévation de privilèges	Rôles par application et vérification serveur des permissions/scopes.	Appliquer les droits côté backend métier, pas uniquement dans l'interface.
Actions non traçables	Journal d'audit avec utilisateur, action, IP et contexte.	Ne pas y écrire mot de passe, secret client ou jeton brut.

> **Configuration locale ≠ production.** L'installation d'exemple utilise localhost et un compte MySQL local. Avant exposition réseau : HTTPS obligatoire, secrets remplacés, compte DB dédié et à privilèges limités, SMTP réel, sauvegardes et politique CORS restrictive.

Durées connues par défaut

session IAM : 1 h · inactivité : 30 min · jeton SSO : 60 s · OTP : 5 min · code OAuth : 5 min · access token OAuth : 15 min · refresh token : 30 jours

08 · INSTALLATION ET EXPLOITATION

Installer, configurer, vérifier

Prérequis locaux

- Apache avec PHP 8.x et extensions PDO MySQL, OpenSSL et mbstring.
- MySQL; la base par défaut est `iam_local`.
- Composer pour PHPMailer et les dépendances OAuth.
- WAMP/XAMPP ou environnement équivalent; démarrer Apache et MySQL avant l'installation.

Séquence d'installation

1. Placer le dépôt dans le document root web sous `IAM-Local`.
2. Ouvrir `/IAM-Local/install.php`.
3. Renseigner l'URL de base, la connexion MySQL et le compte administrateur initial.
4. Choisir si les données de démonstration doivent être chargées.
5. Enregistrer le mot de passe initial de façon sûre, changer-le à la première connexion, puis contrôler les comptes et rôles.
6. Installer les dépendances Composer avec `composer install` si elles ne sont pas déjà présentes.

Points de contrôle après installation

Connexion
Le login accepte les identifiants prévus; MFA et SMTP réagissent selon la configuration.

Portail
L'application apparaît uniquement si elle est active et l'utilisateur autorisé.

SSO PHP
L'état d'intégration indique garde déployé, manuel ou erreur de chemin/droits.

OIDC
Découverte JSON, callbacks, PKCE, UserInfo et JWKS sont atteignables.

> **Ne pas relancer une réinstallation sans sauvegarde.** L'installateur est conçu pour initialiser/mettre à niveau; vérifier son comportement et sauvegarder la base avant toute opération de maintenance sur des données utiles.

Dépannage rapide

Symptôme	Vérifications
Application absente du portail	Active; utilisateur lié à un rôle de cette application; rôle avec permissions attendues.
Jeton SSO invalide	Recommencer depuis le portail; jeton expiré ou déjà consommé; vérifier l'app_code et l'application cible.

Garde PHP non actif	État de déploiement, chemin local, écriture du fichier, module PHP Apache et `.htaccess`.
OIDC redirect_uri invalide	URI callback exactement identique à celle enregistrée, y compris schéma, port et slash final.
Flutter n’échange pas le code	Client public, aucune authentification par secret, PKCE S256, verifier/challenge issus de la même transaction.

09 · LIMITES ET PLAN DE COMPRÉHENSION

Ce qu’il faut retenir

Forces du projet

- Parcours identités, MFA et SSO déjà réunis.
- Console pour utilisateurs, applications, rôles, permissions et audit.
- Modèle RBAC par application inspiré des clients/roles.
- SSO natif simple pour les applications PHP locales.
- OIDC utilisable par des clients confidentiels et publics PKCE.

Limites à garder visibles

- Le garde auto-déployé n’est pas universel : il protège les applications PHP compatibles.
- Un framework externe doit avoir un connecteur OIDC ou un adaptateur préinstallé.
- UserInfo OIDC ne fournit pas actuellement les rôles applicatifs.
- Les données métier des applications clientes restent dans leurs propres bases.
- L’environnement local de démonstration n’est pas un profil production.

Ordre de lecture conseillé du code

1. `install.php` et `sql/schema.sql` : initialisation et modèle de données.
2. `includes/functions.php` : sessions, utilisateurs, RBAC, OTP, tokens et audit.
3. `login.php`, `mfa.php` et `portal.php` : parcours utilisateur.
4. `sso/authorize.php`, `api/sso/validate.php` et `admin/_sso_generator.php` : SSO natif.
5. `includes/oauth.php`, `oauth.php` et `api/oauth/` : OIDC.
6. `admin/` : workflows graphiques et contrôles des données.

Glossaire

IAM : gestion des identités et accès. **SSO** : connexion unique entre applications. **OIDC** : protocole d’identité basé sur OAuth 2.0. **RBAC** : droits attribués par rôle. **PKCE** : preuve cryptographique qui protège l’échange du code pour les clients publics. **JWKS** : publication des clés publiques nécessaires à la vérification des jetons signés.

---

10 · MANUEL D'UTILISATION

Première connexion et navigation

Cette partie explique les actions courantes dans l'interface, sans avoir besoin de lire le code.

Ouvrir une session

1. Ouvrir `http://localhost/IAM-Local/login.php`.
2. Saisir l'identifiant ou l'adresse e-mail et le mot de passe transmis par l'administrateur.
3. Dans la configuration actuelle, le MFA est demandé aux comptes non administrateurs. Saisir le code reçu par e-mail; sans SMTP configuré, le mode de démonstration affiche le code à l'écran.
4. Si un changement de mot de passe est demandé, le faire avant de continuer.
5. Le portail affiche les applications actives auxquelles le compte a reçu un rôle.

Portail utilisateur

Ouvrir une application, consulter le profil, changer le mot de passe et voir ses sessions selon les options disponibles.

Console d'administration

Accessible depuis `/admin/` aux administrateurs IAM. Un rôle « admin » métier dans une autre application ne donne pas ces droits.

Déconnexion et sessions

La déconnexion ferme la session IAM courante. Un administrateur peut révoquer une session depuis **Administration** → **Sessions**; l'utilisateur peut fermer ses autres sessions depuis son profil. Valeurs par défaut : durée maximale d'une heure et déconnexion après 30 minutes d'inactivité.

> **Incident de sécurité.** Désactiver le compte puis révoquer ses sessions; retirer uniquement son accès à une application ne coupe pas une session déjà ouverte.

11 · COMPTES ET ORGANISATION

Créer et administrer les utilisateurs

Créer un compte

1. Ouvrir **Administration** → **Utilisateurs** → **Nouvel utilisateur**.
2. Renseigner prénom, nom, e-mail et mot de passe; compléter téléphone, identifiant, matricule et informations de poste si connus.
3. Choisir l'organisation si elle est déjà créée. Les rôles sont attribuables depuis cette fiche ou depuis la carte de l'application.
4. Enregistrer et transmettre les informations d'accès par un canal sûr.

Modifier, réinitialiser ou désactiver

- Rechercher la personne par nom, e-mail ou matricule; utiliser **Modifier** pour le profil, l'organisation, les groupes, le statut et les rôles.
- Utiliser **Réinitialiser le mot de passe** en cas d'oubli, puis communiquer le nouveau mot de passe de façon sécurisée.
- Désactiver un compte pour interdire les prochaines connexions; révoquer aussi les sessions ouvertes si nécessaire.
- La suppression est définitive; le compte administrateur principal est protégé.

Importer plusieurs personnes par CSV

1. Dans **Utilisateurs**, télécharger le modèle CSV fourni par l'interface.
2. Conserver les en-têtes. Les colonnes obligatoires sont `email`, `first_name` et `last_name`; les autres couvrent identifiant, téléphone, matricule, organisation, direction, service, fonction et statut.
3. Remplir en UTF-8; virgule ou point-virgule est accepté. Les e-mails déjà existants sont ignorés.
4. Importer et lire le bilan des comptes créés, doublons et lignes rejetées; distribuer les accès temporairement par un canal sûr.

> Créer d'abord les organisations, puis les utilisateurs : le rattachement hiérarchique sera disponible dans leurs formulaires.

12 · AJOUTER UNE APPLICATION

Suivre l’assistant d’intégration

Ouvrir **Administration** → **Applications** → **Ajouter une application**. L’assistant en trois étapes enregistre le projet au catalogue et vérifie le type d’installation.

Étape 1 — Informations de l’application

1. Saisir le nom affiché aux utilisateurs.
2. Vérifier le code technique proposé; il doit être unique et utilise lettres minuscules, chiffres et tirets.
3. Saisir l’URL que les utilisateurs ouvriront, puis une description facultative.
4. Cliquer sur **Continuer**.

Étape 2 — Connexion IAM

1. Le SSO natif est le parcours prévu pour un garde PHP. Pour Django ou Flutter, ouvrir **OAuth / OIDC**.
2. Cocher « Redemander le mot de passe IAM » uniquement si la politique le demande à chaque accès direct.
3. Cliquer sur **Vérifier la configuration**. Lire chaque contrôle : code disponible, URL, dossier local, droits d’écriture, serveur PHP.
4. Un projet distant ou non inscriptible peut continuer en installation manuelle; son fichier de garde sera téléchargeable après création.

Étape 3 — Vérification et création

1. Vérifier nom, code, URL et mode d’installation.
2. Laisser désactivé tant que rôles et accès ne sont pas prêts; cocher « Activer dès sa création » seulement si la configuration est déjà préparée.
3. Cliquer sur **Créer et installer**. Le serveur répète les validations avant l’enregistrement.
4. Créer les permissions puis les rôles, attribuer un rôle à un utilisateur, activer et utiliser **Tester le parcours SSO**.

> **Une application n’a pas automatiquement de rôles.** La liste des rôles vide est normale à la création : les rôles sont propres à chaque application et se configurent séparément.

13 · PERMISSIONS ET ACCÈS

Définir qui peut faire quoi

Permissions
Actions métier reconnues par l'application.

→

Rôles
Profils qui regroupent les permissions.

→

Utilisateurs
Personnes autorisées dans l'application.

Créer les permissions

Dans la carte d'application, ouvrir **Permissions** puis ajouter nom, code et description. Exemples : `mnt.equipement.view`, `mnt.intervention.assign` ou `mnt.piece.manage`. Les codes doivent être contrôlés par le backend métier pour réellement protéger les actions.

Créer un rôle et lui affecter des droits

1. Ouvrir **Rôles & permissions** → **Créer un rôle**.
2. Définir son nom, son code, sa description et choisir l'application propriétaire.
3. Sur la carte du rôle, ouvrir **Permissions**, cocher les droits nécessaires et enregistrer.

Attribuer le rôle à une personne

1. Dans la carte de l'application, ouvrir **Accès utilisateurs**.
2. Choisir un utilisateur actif et un rôle de cette application.
3. Cliquer sur **Donner l'accès**. Pour retirer l'accès, utiliser l'action de retrait dans la liste.

Rôle type	Exemple de périmètre
Lecteur / auditeur	Consultation; export seulement s'il est explicitement accordé.
Agent / opérateur	Consultation et saisie limitée à son activité.
Gestionnaire	Création, modification, affectation et validation selon le métier.
Admin applicatif	Administration de son application; ne donne pas l'administration de la plateforme IAM.

> **Moindre privilège.** Ne pas donner un rôle d'administration pour résoudre un manque de permission ponctuel. Ajouter plutôt la permission exacte au rôle métier concerné.

14 · OPÉRATIONS QUOTIDIENNES

Groupes, organisations, sessions et audit

Organisations

1. Créer les niveaux racines.
2. Ajouter directions, services et bureaux en choisissant leur parent.
3. Rattacher les utilisateurs depuis leur fiche.

Une organisation utilisée doit être vidée ou ses utilisateurs déplacés avant suppression.

Groupes

1. Ouvrir **Groupes** → **Nouveau groupe**.
2. Nommer et décrire le groupe.
3. Ouvrir **Modifier** pour choisir ses membres; les groupes peuvent aussi être cochés dans la fiche utilisateur.

Un groupe organise les personnes; il ne remplace pas un rôle applicatif.

Sessions

Filtrer par utilisateur, lire IP/navigateur/activité, puis révoquer une session précise ou toutes les sessions d'un compte.

Audit

Rechercher par compte, action ou IP. Contrôler les connexions, changements de droits, opérations SSO/OIDC et révocations.

Paramètres et MFA

Administration → **Paramètres** permet d'ajuster complexité, historique, expiration du mot de passe, verrouillage et durées de session. **E-mail & MFA** contient les paramètres de livraison des codes. Sans SMTP fonctionnel, les codes sont visibles en mode de démonstration; ne pas utiliser ce mode en production.

> **Point à connaître.** L'état MFA et la règle qui l'impose dépendent de la configuration; la MFA n'est pas un rôle. Un utilisateur peut être autorisé par rôle et néanmoins devoir passer le second facteur avant d'entrer.

15 · OAUTH / OIDC

Configurer une application non-PHP

Ouvrir **Administration** → **OAuth / OIDC** → **Nouveau client** et choisir une plateforme. L'assistant enregistre le client et affiche un récapitulatif de paramètres; il ne modifie pas le code d'un projet externe.

Choix	Configuration	Règle de sécurité
Django / serveur web	Callback HTTPS exacte; Authorization Code; scopes openid/profile/email.	Secret visible une seule fois, à garder côté serveur.
Flutter mobile	Callback avec schéma de l'application; client public Authorization Code.	Pas de secret; PKCE S256 est obligatoire.
Service API	Client Credentials; pas de callback ni d'utilisateur interactif.	Secret côté serveur et scopes machine autorisés.

Paramètres à renseigner dans le connecteur OIDC

- Issuer : URL IAM indiquée dans le récapitulatif.
- Découverte : `/.well-known/openid-configuration.php`.
- Client ID; secret uniquement pour serveur/service confidentiel.
- URI callback exactement identique; scopes autorisés affichés.
- Pour Flutter : redirect scheme exact et PKCE S256; jamais incorporer un secret à l'application.

> **Test fonctionnel.** Lancer le login depuis l'application, approuver le consentement, confirmer le retour à l'URI, vérifier le profil UserInfo puis tester déconnexion et session expirée.

> **Les rôles RBAC ne sont pas encore des claims UserInfo.** OIDC renvoie l'identité/profil. Les permissions applicatives doivent être ajoutées à une future extension de claims ou vérifiées via un endpoint adapté.

Scénario complet et dépannage

Ouvrir une application de bout en bout

1. Créer l'application au catalogue et lancer le prédiagnostic.
2. Ajouter ses permissions correspondant aux opérations métier réelles.
3. Créer des rôles propres à l'application et attacher les permissions.
4. Créer les utilisateurs ou les importer; créer l'organisation au préalable si nécessaire.
5. Attribuer un rôle à chaque utilisateur dans la bonne application.
6. Configurer le garde PHP ou enregistrer un client OIDC adapté.
7. Activer l'application, se connecter avec un compte de test à privilèges minimaux.
8. Contrôler une action permise, une action interdite et l'événement d'audit correspondant.

Symptôme	Cause à vérifier	Action
Application invisible	Application inactive ou aucun rôle utilisateur.	Activer après préparation et attribuer le bon rôle.
Liste des rôles vide	Aucun rôle n'appartient à cette application.	Créer un rôle avec cette application comme propriétaire.
Erreur 403 après login	Permission absente, mauvais rôle ou backend métier qui refuse correctement.	Vérifier rôle, permission puis contrôle côté serveur.
Jeton SSO invalide	Jeton court déjà utilisé, expiré ou code application différent.	Repartir du portail pour obtenir un nouveau jeton.
Callback OIDC refusé	URI, port, schéma ou slash final différent.	Copier exactement l'URI enregistrée dans les deux côtés.
Flutter invalid_client	Client mobile configuré comme confidentiel ou PKCE absent.	Utiliser profil public, sans secret et PKCE S256.
MFA non reçu	SMTP absent ou erreur de livraison.	Vérifier E-mail & MFA; le mode démo n'est que local.

> **Pour diagnostiquer rapidement :** séparer authentification (qui est connecté ?), autorisation (quel rôle/permission ?) et intégration (le client a-t-il correctement ouvert sa session ?).